

تويد - قائمة تحقق تمهيدية للمستشار القانوني

مراجعة نظام حماية البيانات الشخصية والامتثال التنظيمي السعودي - معدة للمستشار القانوني المتخصص في

الخصوصية

أعدت بتاريخ 20-07-2026

تويد منتج سحابي (SaaS) سعودي يحل بيانات مطالبات التأمين الصحي للعيادات (منصة لإدارة المطالبات المرفوضة واسترداد الإيرادات) - وهو برنامج إداري ومالي، وليس جهازاً طبياً أو أداة لدعم القرار السريري. يستضاف المنتج داخل المملكة (منطقة الرياض على Oracle Cloud / منطقة الرياض على AWS)، ويستخدم مزود نموذج لغوي كبير مقره الولايات المتحدة كجهة معالجة فرعية لميزاته المعتمدة على الذكاء الاصطناعي (شرح أسباب الرفض، صياغة التظلمات، استخراج (Anthropic) المستندات). فيما يلي النقاط التي نود تغطيتها في تكليف محدد النطاق قبل معالجة أي بيانات مطالبات حقيقية للمرضى في بيئة الإنتاج.

1. تدفق البيانات واتفاقية معالجة البيانات (DPA)

[] مراجعة تدفق البيانات الفعلي لدينا من البداية للنهاية والتأكد من عدم خروج أي بيانات صحية شخصية عبر حدود المملكة في أي جزء من النظام - بما يشمل السجلات (logging)، والتحليلات، والنسخ الاحتياطية، والبريد الإلكتروني التشغيلي، وليس فقط مسار استدعاء الذكاء الاصطناعي الواضح.

[] صياغة نموذج اتفاقية معالجة البيانات (DPA) القياسي الخاص بنا لاستخدامه مع العيادات العميلة.

2. نقل البيانات عبر الحدود لجهة المعالجة الفرعية للذكاء الاصطناعي - البنود التعاقدية القياسية وتقييم المخاطر

[] التأكد من أن البنود التعاقدية القياسية السعودية (نموذج جهة تحكم إلى جهة معالجة) هي الضمانة المناسبة لنقل البيانات إلى مزود النموذج اللغوي الكبير الأمريكي (Anthropic). لم تنشر الهيئة السعودية للبيانات والذكاء الاصطناعي (سدايا) أي 'قائمة كفاية' للدول الوجهة المعتمدة، لذا فإن استخدام إحدى الضمانات المناسبة هو المسار متاح بحكم عدم وجود بديل.

[] إعداد تقييم المخاطر الإلزامي الذي تشترطه سدايا لعمليات نقل البيانات الحساسة/الصحية عبر الحدود (وفق دليل تقييم المخاطر الصادر عن سدايا في فبراير 2025، باستخدام أداة التقييم الذاتي المتوفرة على منصة حوكمة البيانات الوطنية (dgp.sdaia.gov.sa)). نفهم أن هذا يتطلب إلزامي وليس إجراء ورقياً اختيارياً، متى ما تم الاعتماد على إحدى الضمانات المناسبة لبيانات حساسة.

3. الشروط والأحكام الخاصة بمنصة نفيس - قراءة لتقييم المخاطر التجارية

[] نعمل على منصة نفيس (nphies.sa)، وهي منصة التبادل الوطنية لمطالبات التأمين الصحي في المملكة. تتضمن صفحة الشروط والأحكام الخاصة بها (nphies.sa/terms-and-conditions) اتفاقية ملزمة تشمل: بندا لتحديد المسؤولية، وبندا للتعويض لصالح نفيس، وحقا منفردا لنفيس في إيقاف أو إنهاء الوصول دون إشعار مسبق. نرجو مراجعتها وتقديم رأيكم: هل هذا مستوى مخاطرة مقبول للعمل بموجبه، أم يحتاج إلى معالجة (مثل صياغة تعاقدية مع عياداتنا العميلة توزع هذه المخاطرة)؟

[] سؤال محدد رقم 1: ينص بند إخلاء المسؤولية عن الضمانات في الشروط على أن الاتصالات التي يرسلها المستخدم عبر المنصة لا تحمل أي ضمان سرية من جانب نفيس. هل يمكن أن يمتد هذا البند إلى بيانات المطالبات الفعلية (FHIR) المرسلة

عبر المنصة، أم أنه مقتصر على قنوات الدعم العامة (نماذج التواصل، المحادثة الفورية)؟ لا نرغب في افتراض الإجابة بأي اتجاه.

[] سؤال محدد رقم 2: يمنع بند الملكية الفكرية في الشروط إعادة التوزيع أو إنشاء أعمال مشتقة من محتوى المنصة دون موافقة خطية من نفيس. بشكل منفصل، فإن حزمة المواصفات التقنية التي نتكامل معها (دليل تطبيق نفيس - NPHIES السعودية) تحمل إشعار حقوق نشر خاصا بها دون منح مفتوح المصدر HL7 الصادر عن، Implementation Guide، غير مقيد. بالجمع بين الأمرين، هل يعني هذا أننا فعليا لا يمكننا تضمين أي مواد تقنية مشتقة من نفيس في منتجنا أو في أنظمة التكامل المستمر (CI) دون موافقة خطية من نفيس / HL7 السعودية؟

4. خطة الاستجابة للاختراقات

[] مساعدتنا في صياغة خطة استجابة للاختراقات تلي متطلب سدايا بالإبلاغ خلال 72 ساعة. لا يوجد حد أدنى لجسامة الحادث ولا استثناءات، أي أن كل حادث - مهما كان حجمه - يعد قابلا للإبلاغ بحسب فهمنا. يجب أن تغطي الخطة: الاكتشاف، إبلاغ سدايا خلال 72 ساعة، وإبلاغ أصحاب البيانات المتأثرين 'دون تأخير غير مبرر' متى ما كان هناك احتمال ضرر.

5. تحديد صفة جهة التحكم مقابل جهة المعالجة، والتسجيل، ومسؤول حماية البيانات

[] تحديد ما إذا كنا جهة تحكم أو جهة معالجة في علاقتنا مع العيادات العميلة. افتراضنا الحالي هو أن العيادة هي جهة التحكم ونحن جهة المعالجة - نرجو تأكيد ذلك بدلا من تركنا نفترضه.

[] بناء على تلك الإجابة: هل يترتب علينا التسجيل في منصة حوكمة البيانات الوطنية التابعة لسدايا، أو تعيين مسؤول حماية بيانات إلزامي؟ نفهم أن هذه الالتزامات تقع عموما على جهة التحكم، لكن نرجو التأكد من أن طبيعة عملنا الخاصة لا تغير ذلك.

[] أيا كانت الجهة المسؤولة رسميا عن إبلاغ سدايا بالحادث، نرجو التأكيد بأننا - بصفتنا جهة معالجة - نحتاج إلى إبلاغ العيادة بسرعة كافية لتتمكن هي من الالتزام بمهلة الـ 72 ساعة الخاصة بها، بغض النظر عن نتيجة تحديد صفة التحكم/المعالجة أعلاه.

6. نقاط تحقق سريعة

[] محيط أنشطة البنك المركزي السعودي (ساما) الخاصة بخدمات الدفع: نموذج إيراداتنا هو رسم أساسي بالإضافة إلى نسبة مئوية من المبالغ المستردة من المطالبات، تفوتر للعيادة كفاتورة تجارية منفصلة (B2B) - وتقوم شركة التأمين بالدفع مباشرة للعيادة، ولا نكون في أي وقت طرفا في مسار الدفع ولا نحتفظ بأي أموال. نرجو التأكيد بأن هذا يبقى خارج نطاق تعريف 'خدمات الدفع' المنظمة من ساما؛ يكفي تأكيد من سطر واحد.

[] مسار التسجيل التجاري: تأكيد أن السجل التجاري السعودي القياسي كاف، دون الحاجة لترخيص استثماري من وزارة الاستثمار، نظرا لأن المؤسس مواطن سعودي.

[] مدى انطباق الإطار التنظيمي للحوسبة السحابية الصادر عن هيئة الاتصالات والفضاء والتقنية (CST): نقوم ببناء تطبيقنا البرمجي الخاص وتشغيله على مزود سحابي خارجي (Oracle Cloud / AWS) - ولا نملك أو نشغل أي مركز بيانات أو بنية تحتية بأنفسنا. هل يستوجب هذا التسجيل لدى هيئة الاتصالات والفضاء والتقنية بصفتنا مزود خدمات حوسبة سحابية؟ تصف معايير التسجيل العامة لدى الهيئة أن المعيار المحدد هو الجهة التي 'تتحكم بشكل مباشر أو فعلي بمركز البيانات أو البنية التحتية الحرجة'، إلا أن مواد الهيئة تشير أيضا إلى أن الإطار 'تم توسيعه ليشمل صراحة خدمات البرمجيات كخدمة (SaaS)'، دون استثناء واضح وجدناه لتطبيق SaaS مبني على بنية تحتية تابعة لجهة أخرى. نود الحصول على رأي قاطع قبل بدء التشغيل الفعلي.

تعكس هذه القائمة قراءتنا الخاصة بحسن نية للأنظمة واللوائح والبوابات الرسمية المتاحة للعموم؛ وهي ليست استشارة قانونية، وكل بند أعلاه هو سؤال موجه للمستشار القانوني للتأكيد أو التصحيح أو التوسيع.